



# VULNERABILITY ASSESSMENT AND PENETRATION TESTING REPORT

|                 |                                                  |
|-----------------|--------------------------------------------------|
| Target Platform | AndroGoat (OWASP Vulnerable Android Application) |
| Lab Category    | Mobile Application Security Testing              |
| Prepared By     | Adbin Magar                                      |
| Internship At   | Eminence Ways Pvt. Ltd.                          |
| Testing Period  | June 2026                                        |
| Classification  | Confidential                                     |

*This report was prepared as an internship assignment at Eminence Ways Pvt. Ltd.  
All testing was completed on AndroGoat in a control training environment.*

Table of Contents

1. Executive Summary ..... 3

2. Scope and Methodology ..... 4

    2.1 Scope of Testing..... 4

    2.2 Testing Approach ..... 4

    2.3 Tools Used..... 4

3. Findings ..... 5

    3.1 Unprotected Android Components..... 5

        UAC-01: Unauthorized Invoice Download via Exported Service ..... 5

4. Remediation Summary..... 8

5. Conclusion ..... 9

6. References..... 10

## 1. Executive Summary

This report documents the findings of a manual mobile application penetration test conducted against AndroGoat, a deliberately insecure Android application designed for security training. The test was performed as part of an internship at Eminence Ways Pvt. Ltd. during June 2026. The target application was installed on a physical OPPO A5 Android device and tested using ADB and Android Studio.

The tester identified one vulnerability in the Unprotected Android Components category. The finding is rated High severity and allows an unauthenticated attacker to invoke a background service directly using ADB without any PIN verification or login, resulting in unauthorized download of sensitive invoice data.

| ID     | Vulnerability                                      | Category                       | CVSSv4 | Severity |
|--------|----------------------------------------------------|--------------------------------|--------|----------|
| UAC-01 | Unauthorized Invoice Download via Exported Service | Unprotected Android Components | 5.2    | Medium   |

## 2. Scope and Methodology

### 2.1 Scope of Testing

| Item                   | Detail                                                |
|------------------------|-------------------------------------------------------|
| Target Application     | AndroGoat v2.0.1                                      |
| Package Name           | owasp.sat.agoat                                       |
| Device                 | OPPO A5 (Physical Device)                             |
| Primary Testing Method | ADB (Android Debug Bridge)                            |
| Out of Scope           | Any application outside the AndroGoat lab environment |

### 2.2 Testing Approach

All testing was conducted manually. ADB was used to communicate between the laptop and the physical Android device over USB. Android Studio was used to inspect the AndroidManifest.xml file for exported components. The general process followed for this finding is described below.

The environment was set up by installing the AndroGoat APK on the OPPO A5 device via Android Studio and enabling USB debugging on the device. The AndroidManifest.xml file was reviewed inside Android Studio to identify any components declared with `android:exported="true"` and no associated permission attribute. The identified exported service was then invoked directly via ADB without any authentication. The resulting file was located on the device storage, and its contents were read using ADB shell commands.

### 2.3 Tools Used

| Tool                                | Purpose                                                                                     |
|-------------------------------------|---------------------------------------------------------------------------------------------|
| <b>ADB (Android Debug Bridge)</b>   | Communicating with the Android device, invoking exported components, reading device storage |
| <b>Android Studio</b>               | Reviewing AndroidManifest.xml to identify exported components                               |
| <b>CMD (Windows Command Prompt)</b> | Running ADB commands against the connected device                                           |

## 3. Findings

### 3.1 Unprotected Android Components

Unprotected Android Components refer to application components such as Activities, Services, and Broadcast Receivers that are declared with `android:exported="true"` in the `AndroidManifest.xml` file without any permission restriction. This means any external application or attacker with ADB access can invoke these components directly, bypassing any authentication or access control the application enforces through its normal user interface.

#### UAC-01: Unauthorized Invoice Download via Exported Service

|                             |                                                                        |
|-----------------------------|------------------------------------------------------------------------|
| <b>Vulnerability Name</b>   | <b>Unauthorized Invoice Download via Exported Service</b>              |
| <b>Application Affected</b> | AndroGoat v2.0.1 (owasp.sat.agoat)                                     |
| <b>Vulnerable Endpoint</b>  | .DownloadInvoiceService                                                |
| <b>Location</b>             | AndroidManifest.xml Line 114                                           |
| <b>CVSSv4 Score</b>         | 5.2                                                                    |
| <b>CVSSv4 Severity</b>      | Medium                                                                 |
| <b>CVSSv4 Vector</b>        | <a href="#">AV:P/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N</a> |
| <b>Tools Used</b>           | ADB, Android Studio, CMD                                               |

#### Description

The `AndroidManifest.xml` file declares a service component named `.DownloadInvoiceService` with `android:exported="true"` and no `android:permission` attribute defined. This means the service is fully accessible to any external caller without any authorization check. Under normal application flow, a user must verify a PIN before downloading an invoice. However, because the service responsible for downloading the invoice is exported without restriction, an attacker can invoke it directly using an ADB command and bypass the PIN verification entirely. The application places no server-side or component-level access control on the service itself and relies only on the PIN screen in the user interface as a gate, which can be skipped completely by calling the service directly.

#### Impact

- Any attacker with ADB access or a malicious application installed on the same device can invoke the `DownloadInvoiceService` without knowing the PIN or holding any valid session.
- Sensitive invoice data is downloaded to the device storage and becomes readable without authentication.
- The barrier to exploitation is very low as the attack requires a single ADB command and no prior knowledge of credentials.

#### Steps of Reproduction / Proof of Concept (PoC)

1. The tester opens AndroidManifest.xml in Android Studio and searches for the keyword “invoice”. The file reveals a service declaration with android:name=".DownloadInvoiceService", android:enabled="true", and android:exported="true" with no permission attribute defined.



Fig: AndroidManifest.xml showing .DownloadInvoiceService declared with android:exported="true"

2. The tester confirms the device is connected and recognized by ADB.

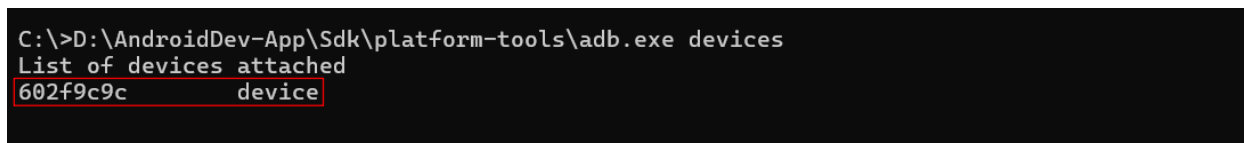


Fig: ADB devices output confirming the OPPO A5 is connected and authorized

3. The tester runs the dumpsys command to enumerate package activities and confirm the package name.

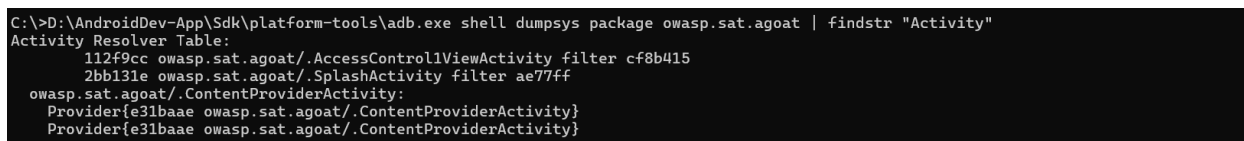


Fig: ADB dumpsys output listing the package activities and confirming the package name

4. The tester invokes the exported service directly using ADB without providing any PIN or credentials. The service starts immediately and downloads the invoice to device storage.

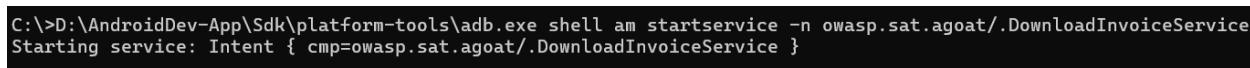


Fig: ADB startservice command invoking .DownloadInvoiceService without any authentication:

5. The tester locates the downloaded invoice file on the device storage.

```
C:\>D:\AndroidDev-App\Sdk\platform-tools\adb.exe shell ls /sdcard/Download/  
1780829765088_invoice.txt
```

*Fig: ADB shell ls output showing the invoice file downloaded to /sdcard/Download/*

6. The tester reads the invoice contents directly from device storage using ADB, confirming that sensitive data was obtained without any PIN or login.

```
C:\>D:\AndroidDev-App\Sdk\platform-tools\adb.exe shell cat "/sdcard/Download/1780829765088_invoice.txt"  
This is invoice for product purchased on Aug 12th.  
  
Thanks,  
AndroGoat
```

*Fig: ADB shell cat output displaying the invoice contents without any authentication*

## Remediation

- Set android:exported="false" on the DownloadInvoiceService declaration in AndroidManifest.xml so that the service cannot be invoked by external callers.
- If the service must remain exported for legitimate inter-app communication, define a custom signature-level permission using android:permission and enforce it on the service declaration.
- Move access control enforcement to the service level rather than relying solely on the PIN screen in the user interface, so that direct component invocation cannot bypass authentication.

## References

- OWASP Mobile Top 10 M1: Improper Platform Usage: [owasp.org/www-project-mobile-top-10](https://owasp.org/www-project-mobile-top-10)
- Android Developer Docs on exported components: [developer.android.com/guide/topics/manifest/service-element](https://developer.android.com/guide/topics/manifest/service-element)
- OWASP Mobile Security Testing Guide: [mas.owasp.org/MASTG](https://mas.owasp.org/MASTG)

## 4. Remediation Summary

| ID     | Vulnerability                                      | CVSSv4 | Severity | Primary Remediation                                                                                              |
|--------|----------------------------------------------------|--------|----------|------------------------------------------------------------------------------------------------------------------|
| UAC-01 | Unauthorized Invoice Download via Exported Service | 5.2    | Medium   | Set android:exported="false" on .DownloadInvoiceService or enforce a signature-level permission on the component |



## 5. Conclusion

This report presents the findings of a manual mobile application penetration test conducted against AndroGoat as part of an internship at Eminence Ways Pvt. Ltd. during June 2026. The tester identifies one vulnerability in the Unprotected Android Components category that allows complete bypass of the PIN verification mechanism through direct ADB invocation of an exported service.

The finding demonstrates how placing access control only at the user interface level creates a significant gap when the underlying component is accessible without restriction. The normal application flow requires a PIN before an invoice can be downloaded. However, because the `DownloadInvoiceService` component is declared with `android:exported="true"` and no permission attribute, the PIN screen is entirely irrelevant to an attacker who communicates with the component directly. The invoice was obtained with a single ADB command, and its contents were confirmed using standard shell tools.

The remediation for this finding is straightforward. Setting `android:exported="false"` removes external access to the service entirely and does not require any changes to the application business logic. This finding highlights that access control in Android applications must be enforced at the component level inside `AndroidManifest.xml` and not only through the screens presented to the user.

## 6. References

- OWASP Mobile Top 10 M1 Improper Platform Usage: [owasp.org/www-project-mobile-top-10](https://owasp.org/www-project-mobile-top-10)
- Android Manifest Service Element Documentation: [developer.android.com/guide/topics/manifest/service-element](https://developer.android.com/guide/topics/manifest/service-element)
- OWASP Mobile Security Testing Guide (MASTG): [mas.owasp.org/MASTG](https://mas.owasp.org/MASTG)
- AndroGoat Project: [github.com/satishpatnayak/AndroGoat](https://github.com/satishpatnayak/AndroGoat)
- Android Debug Bridge (ADB) Documentation: [developer.android.com/studio/command-line/adb](https://developer.android.com/studio/command-line/adb)

*End of Report*  
**Eminence Ways Pvt. Ltd.**